

For this, true data spreading is required and special procedures must be followed, which may not be supported by the standard API (or at all). Therefore, an effective encryption mechanism is required to reduce this risk.

Conflicts between customer hardening procedures and the cloud environment: Cloud providers follow different server or instance hardening mechanisms, which are a little different from traditional server hardening procedures. As an example, AWS and its EC2 service follow security group and IAM roles for securing and authenticating instances, while physical servers (Linux or Windows) follow traditional methods for hardening.

Users must understand clearly the hardening procedures of cloud providers and which best practices are being used for hardening.

Loss of encryption keys: This includes the disclosure of secret keys (file encryption, SSL, customer private keys, etc) or passwords to malicious parties, the loss or corruption of those keys, or their unauthorised use for authentication and non-repudiation (digital signature) purposes.

Malicious probes or scams: Malicious probes or scanning, as well as network mapping, are indirect threats to data assets. They can be used to collect information in the context of a hacking effort. A probable impact could be a loss of confidentiality, integrity and availability of services and data.

A compromised service engine: Every cloud provider relies either on an extremely specific platform or the service engine that sits just above the physical hardware and manages customer requests at different levels of abstraction. For instance, with infrastructure service providers, this software element can be the hypervisor. For platform service providers, it could be hosted application engines.

Hacking the service engine may be useful to escape the isolation between different customer environments (jailbreak) and to gain access to the data contained in them, to monitor and adapt the information inside them in a transparent way (without direct interaction with the application inside the customer environment), or to decrease the resources assigned to them, causing a denial of service (DoS) attack.

Legal risks

Risk from changes in jurisdiction: Customer data may be kept at several locations with varying jurisdictions, some of which may be of high risk. For instance, data centres could be located in high-risk countries lacking an enforceable rule of law, with an unpredictable legal framework, dictatorial police states, states that do not respect international agreements, etc. Sites could be attacked by local authorities and data or systems, subject to enforced disclosure or seizure.

Licensing risks: Licensing conditions, such as per-seat agreement and online licensing checks, may become unusable

in a cloud environment. For example, software is charged at a 'per instances' basis, so if the cloud-based instance increases, the cost of the software also increases exponentially.

Data protection risks: It can be tough for the cloud customer (in the role of data controller) to efficiently check the data processing that the cloud provider brings out and, therefore, be sure that the data is handled in a lawful manner. There may be data security breaches of which the controller is not warned by the cloud provider.

The cloud customer may misplace control of the data administered by the cloud provider. This issue gets highlighted in the case of multiple transfers of data (e.g., between federated cloud providers).

Other risks

When backups get lost or stolen: This risk is due to inadequate physical security procedures, user provisioning vulnerabilities and user de-provisioning vulnerabilities.

Unauthorised access to premises (including physical access to machines and other facilities): Due to inadequate physical security procedures, unauthorised access in data centres is possible. Generally, cloud providers have large data centres. Therefore, physical control of the data centre must be stronger because the impact of a breach could be higher.

Theft of computer equipment: This risk occurs due to inadequate physical security procedures, particularly with relation to data centres. Only authenticated persons must be allowed to enter physical data centres and a dual authentication mechanism should be followed in order to access those machines.

Natural disasters: Natural disasters are possible at any time, so there must be a perfect disaster recovery plan.

The risk from natural disasters is much less than in traditional infrastructure because cloud providers offer redundancy and fault tolerance, by default. AWS, for example, has various physical regions and multiple availability zone options even within a region.

Open source cloud security solutions

OSSEC- HIDS (Open source security host-based intrusion detection system)

OSSEC (www.ossec.net) is an open source host-based intrusion detection system (HIDS). According to its website: "OSSEC is a scalable, multiplatform, open source Host-based Intrusion Detection System (HIDS). It has a powerful correlation and analysis engine, integrating log analysis, file integrity checking, Windows registry monitoring, centralised policy enforcement, rootkit detection, real-time alerting and active response. It runs on most operating systems, including Linux, OpenBSD, FreeBSD, MacOS, Solaris and Windows."